

Lecture 14

Cybersecurity and Privacy - Supplementary Lecture

Cyber Security and Privacy | NPTEL 106106248

Prof. Saji K. Mathew, IIT Madras

Video: <https://www.youtube.com/watch?v=ozsxJCM4BGs>

Study transcript from publicly available YouTube captions. Course content and video rights belong to NPTEL / IIT Madras. For personal study only.

are Audible thank you so welcome back once again to the live session of cyber security and privacy course and I want to believe that all of you are enjoying this course in terms of learning new things about our cyber world and I also understand that you have challenges of various kinds in doing the course which is of course expected when you do things online and when you don't meet physically but thank you for the understanding before I start I want to request all the participants to ensure that you go through the weeks videos and readings okay you have to listen to the videos carefully and also read the materials that are given before you shoot questions because there is no point in asking questions which are already answers which are already available in the videos or in the reading materials so that is my request so don't ask questions which are already answered and it's important that you go through the video as well as reading materials there are repeating questions to us to supply reading materials please carefully go through the live video session one about my response to how to get your reading materials and those who ask those questions it is very clear you haven't done your homework so please go through live videos regular week weekly video lessons as well as reading materials and before I forget let me actually share with you the reading for week four which is already which is the videos of which are already available in the platform and of course you have to read the textbook course text chapter 4 is something that you have to read as part of this course and the other material I am actually sharing with you here contingency planning is the topic for week four and you would see that contingency planning is a part of managerial planning for cyber security okay this covers is about cyber security management and it's very important that as part of this course you follow management principles and management Frameworks to control the risk that are caused by the environment okay so there are in so somebody has asked what is this management okay so that is like asking what is this world or what is this universe or what is technology what is science you know very broad question but I will answer that question in simple terms that management is about managing resources okay what is a manager manage it is resources resources are of different types resources are what you use to use for production or creation okay so you need Manpower you need money you need land you need materials you need what else you need technology all these are resources okay so technology is one resource that needs to be managed so it is in that setting that we apply this management principle of plan okay so one important managerial activity is planning okay so if you don't plan then you are not sort of you are not managing your resources efficiently okay you can do things without planning you know how much losses it leads to if you don't plan okay so the only difference between planning and non not planning is that the loss or the cost okay costs are higher or you are actually being very inefficient when you don't plan so in your in this course you will

you are seeing two types of planning one is the contingency planning other is the risk management planning okay so risk management will come later in this course but you see contingency okay the word contingency means it is not predictable okay you don't know they have uncertainty okay as you stand today everything looks good okay when you look at the surroundings well it's a sunny day it's not going to rain and there are no clouds so you believe that the whole day is going to be like that okay but then comes the afternoon and the clouds form in the sky and all of a sudden there is a rain okay well and you get wet or your medicine yeah because you didn't plan for a situation like this okay and even when you you expect a rain to happen in the afternoon but still okay you are not sure okay or your you will plan for it but still despite all the planning things can get worse Suppose there is a tornado along with the rain and suppose there is another let those things not happen Okay so unexpected things do happen so contingency planning is about planning for the unexpected okay that's like that's like a paradox okay so how can you plan for the unexpected one that is what this weeks lesson on cyber security cyber security contingency planning teaches you so you can see that there the impact of events or what we call incidents we deal with incidents we prepare for incidents in contingency planning an incident is something that could happen in future okay so contingency planning and that way is reactive suppose something happens despite all the preparations how do you restore your organization your business your system back to operational condition okay back to the normal running condition that is the purpose of contingency plan let me say this again let's not this important principle leave your mind when you talk about contingency planning we are talking about we are talking about incidents that could happen and if they happen the task before a contingency planning task management group or team cpmt as it is called their role is to restore the systems back to normal operation at the minimum time okay earliest possible okay and you will also see in contingency planning the earliest you know should we looked at very carefully earliest can mean with zero loss or in not time or without any loss of time if a system could be restored that is the best okay a system could also be restored you can just like let things go on and restore it at your own Leisure okay so it's like Polar Opposites but zero downtime is possible but it introduces another cost okay and that is what you will see okay so the the higher the Target that you set for sort of or the shorter the Target that you set for downtime the higher the cost of restoring the system to normal operation because you have to invest in when you have to invest in systems or in you have to create redundancy so that if a system fails another system takes over so that is an investment okay so there is a cost involved in it and therefore there is a trade-off between these two costs cost of downtime versus cost of restoration okay so please understand those two two aspects of cost and the the optimal point is the point of the two curves as you see in this lecture okay and so the principles of contingency planning are further explained in the course there are three types of incidents as you will see the you know the normal incident which doesn't cost much say where one machine is affected versus a disaster where your entire operations are shut or your entire business running or India production unit is shut okay your banking operations are all down if if you're running on e-banking so therefore you need you may have to the impact is very high okay so you may have to shift to an alternate location and that's what Disaster Recovery means disaster means the place that you're operating in is destroyed okay you can't operate there anymore okay if you are

operating in Adair in Chennai and your unit of operation is there whatever business that you're doing okay be manufacturing lead Services be it anything okay you in in a disaster situation you cannot operate there anymore you have to move your entire unit to another location and that's called Disaster Recovery okay sorry business continuity I'm sorry I'm sorry I'm sorry business continuity okay so what is between business continuity and a incident okay a normal incident is the disaster sorry I I think I use the words wrongly I apologize Disaster Recovery is recovery to the same location you don't change the place business continuity is when you come you cannot operate there anymore you need to move out of that place that is called business continuity planning BCP right Disaster Recovery is about recovering the system from a disaster but to the same location okay so so then before disaster or before the incident during the incident post incident what are the activities and what are the plannings what are the planning and then what are the activities based on the plans that a unique can do is what is explained in contingency plan okay so go through the lessons carefully and understand the principles of contingency planning and you also we also have discussed the case of I Premiere okay I Premiere a actually describes it has a narrative of what happened in an organization in an young e-commerce organization when there was a distributed denial of service attack and you could see from the case the way it was presented that the organization was not prepared and everyone starts blaming the other because they are not prepared so an important thing as as technical people and also managers I I see the audience as both you need to have managerial ability you also need to understand technology okay so how would you actually what would you do to prepare this organization for future is an important task okay of course at the end of the case that discussion you would see okay so how what are the steps that the organization is taking to treat cyber security seriously okay so lack of contingency planning leads to un expected down times okay serious down times and that could be sometimes disaster that could call for business continuity sometimes in the sense you have to shift location this happens because two reasons one is that your protection mechanisms are not sound enough second despite things happening you will start blaming each other or start staring at the walls because you're not prepared you don't know what to do when there is a major incident okay so be prepared even if you have done all risk management activities you have invested in protection mechanisms by technology by people and so on but still things could go wrong and be prepared that is the meaning of contingency planning okay now I have shared the readings for the week and now let me go through some of the questions that have come from the participants we again my TN vinod Kumar has classified the questions so so I find that a lot of questions have sort of questions these are questions regarding submission of assignments what happens if the assignment is not submitted or delayed you know will I get my certificate and so on so these see nptel platform runs based on clearly defined rules okay so you will get response from the from the nbital team on this on this questions related to the platform rules okay so even I am not competent to respond to some of the questions about what happens if it delays Etc okay or so there may be nuances so the team will be answering your questions but the best way is have a weekly plan for listening to the videos okay sit apart maybe every day one hour okay that's up to your work schedule okay so you have to spend time to understand this course and then read the materials for example chapter four of the textbook is the reading for last week and this week unless you read you don't learn okay and if

you don't learn you cannot answer the assignments okay so don't miss the assignments and if you miss assignments regularly then it's going to be a problem especially if you want a certificate okay I'm not answering questions questions related to the reading materials which was cases Etc because they have already been answered there is a question sir is this cyber security used in phone I don't know what is the meaning of this question but I presume that the question is related to smartphones and maybe the question this participant is asking if I assume that our smartphones vulnerable okay so you want to think that say servers and PCs are vulnerable but smartphones are not but they are vulnerable okay there are different types of attack that happens on phones you must have heard about the major case of an Israeli firm snooping on Indian politicians okay let me not mention the name of that case but it's politically charged but it did happen Okay so tell if the data stored in your cell phone in in cell phones were stolen by malware okay so they do happen Okay and another important source of Cyber attack as far as phones are concerned is phishing okay let me write down the spelling it is the it is phishing are supplied to phones or voice it is called phishing phishing is the sort of calls that you get from Unknown People okay and they call you up and they are imposterous they act as if they are going to be very benevolent and doing to advise you or are going to help you Etc and then try to gather information from you or make offers to you for making money and so on okay so this is known as phishing or spam mails or malicious emails with malicious content that is phishing Phishing voice calls with malicious intention and content is phishing okay that that is actually related to phones since the question is specifically about phones okay then there is another question a difference between technological and managerial vulnerabilities well that's a good question I think it is partly addressed in the first session or in the first week but let me repeat cyber security consists of technology or the risk is actually mostly with the technology but you cannot separate people from technology okay people process technology okay so if you have to give one name for information system or one breakup of information system it is people process technology okay so there are people there are process there are Technologies now if you look at the Target corporation's case you will see that they were vulnerabilities which were exploited by very clever Minds who are known as hackers okay and what what are some of the vulnerabilities that you saw of course there was a problem with the Lan configuration okay so there was a mistake or error in the Lan configuration because of which a vendor could access a POS of a retail company okay that configuration was wrong but was was it a technological vulnerability or a managerial vulnerability that is the question well it is like that that is actually a cause and effect sort of thing okay for example if you describe what is the vulnerability the vulnerability was with the land okay which was exploited and a malware was planted by the hackers so that is what that is the incident now or that was attack now vulnerability was misconfiguration that is what you see as vulnerability but what is the cause of that vulnerability it's a misconfiguration okay it's a human error okay who is responsible for it or who caused it okay so it's like it's like fever and infection right when you have infection you get fever okay but what is causing the fever is the infection right fever is like a symptom so so that way you see the the managerial faults or errors get reflected in technology okay and which leads to cyber attacks so it's management or people which who are integral part of the resources of management they and the management part and the technology part of very intertwined okay so therefore you cannot separate them often okay

both are involved okay but in certain cases you can clearly see that the problem is with the people or it is with the management for example logging okay logging was turned off okay and therefore it was difficult to trace who access the system okay that was the problem with I Premier company right there was no logging and why is logging turned off because you know the system becomes inefficient so who turned it off it's the people who start this off whose decision it was to turn the logging off it was a decision by certain profession certain professional okay so oftentimes if there are money there are no strict management processes okay to ensure that this kind of decisions are not made or this kind of activities don't happen then your systems become well done okay so therefore management and Technology are closely related or intertwined I would say in cyber security and therefore these have to be seen together okay so what can prevent such kind of errors are standards or strong processes okay and that is what you see in when we when you discuss you know the risk management procedures and the standards for cyber security management okay so in the presence of which such incidents can be minimized okay so I hope it is clear especially with the case studies you understand how these two aspects go together in cyber security I have to know another question I have to know what areas this field in what areas these to field differs and what is the role played in security by these two Fields okay I think this question is foreign I think I got disconnected am I audible now yes sir ah sorry yeah so whether Target Corporation Cyber attack happened because they followed technology used by CIA that because I'm not sure because the case only suggests that they had the best technology which is protecting as good as a technology which is protecting a country okay and so that was the kind of investment they made okay that is what the case says and is that the reason why they had vulnerabilities the case doesn't say so the vulnerability is arose because of Tech management failures as is very clear in the case for example misconfiguration and lack of log details Etc these were all errors okay from Human errors I would say okay and therefore despite having the best technology you still can have vulnerabilities that is because of people and that is the bigger cause of data breaches today or in the last one decade that is what we have seen when we look at Major breaches later on in this course you will be discussing a case of Equifax okay Equifax is a major data breach case in the United States and when you go through the details of the documented case you will see that not only management but governance failure also did exist okay which led to that major measure and therefore just to find fault with the technology is not correct or it's not because of CIA technology that the problem occurred okay all right let me go back and is there any question someone has asked suspected assigned okay there is a question regarding assignment question how data custodians data owner is the answer to the question but provide the reason how data custodians are how data custodians are the correct one I don't know if the question is written correctly because I can't understand exactly what the participant is asking but let me take that question and clear your doubt okay that is question related to data owners the question is who are responsible for the security and use of a particular set of information data uses data exporter data custodians data owner okay and the answer was data custodials okay so here are not data owner but here you are supposed to have read the textbook right if you read the textbook the data owners data custodians and data users are defined okay I suggest that you visit page 40 of your textbook which is chapter one so data owners are members of Senior Management who are responsible for the security

and use of a particular set of information the data owners usually determine the level of data classification as well as the changes to that classification required by organizational change okay so data owner is it a higher level Senior Management data custodian is someone who works directly with data on us data custodians are responsible for the information and the systems that process transmit and store it okay so data custodians comes at an operational level okay so say for example a database administrator is the custodian of the data that is stored in a database but database administrator is an employee of an organization okay so suppose your organization's name is XY is it okay X Y is the data owner okay and a certain Department which is responsible for managing the database it could be the IT department they are the data custodians because they do the operational aspect data users are people whose data is stored okay that could be you and me okay in an educational institution the students are the data users okay another related term would be data subjects when we discuss data privacy you will have this term data data subjects also data whose data is stored or processed or transmitted okay they are the data subjects or data users I hope it is clear to you and now you understand why the answer is C which is data custodians all right and so again a small hint here is if you read your textbook well or your materials for the week well then you will be more precise in your understanding about the topic okay these are technical terms okay these are not terms that you can use Loosely okay because these terms have certain definitions okay and definitions of Concepts do matter in academy and therefore read thoroughly and there is no other way okay I think that's all the questions that I have got this week and somebody has said I can't download the video again this is technical question regarding the platform that I'm sure you will hear from them but I I believe these are not given in a way that you can download at the moment but you can watch them okay thank you and look forward to the next week have a great week learning full week do spend time listening to the videos and reading the materials and reflecting on what you learned and that is the time for your assignment okay okay all the best see you again